

IT-Sicherheit

0. Einführung

Prof. Dr. Tobias Straub
Masterprogramm Informatik

www.dhbw.de

Literatur

- Grundlage für einige Teilen der Vorlesung ist das Buch

[Eckert] Claudia Eckert: IT-Sicherheit, Oldenbourg,
Neuaufgabe 2/2023
(ältere Auflage erhältlich als eBook über DHBW Stuttgart)

- weitere empfohlene Bücher

[Pfleeger] Charles P. Pfleeger, Shari Lawrence Pfleeger: Security in
Computing, Prentice Hall

[Stallings] William Stallings, Lawrie Brown: Computer Security,
Pearson

Inhalt

- Grundlagen [Eckert: Kap. 1]
 1. Grundlegende Begriffe
 2. Schutzziele
 3. Schwachstellen und Angriffe
 4. Schutzmaßnahmen, Sicherheitsinfrastruktur
 5. Schwachstellen-Systematisierung und -Management

1. ■ Grundlegende Begriffe

- Klärung und Abgrenzung von Begriffen:
 - Datensicherheit
 - Datensicherung
 - Datenschutz
 - Funktionssicherheit
 - Informationssicherheit



- „sicher“ wogegen?
 - Bedienfehler
 - Hardware-Ausfall
 - techn. Fehler



Sicherheit gegen Bedienfehler

- versehentliches Löschen/Überschreiben von Daten durch Benutzer
- Unkenntnis / Ignoranz

Platz 1: Die Warnung in den Wind schlagen (Kroll Ontrack Spanien)

Ins Kroll Ontrack Labor in Spanien wurde ein defektes RAID5 eingeschickt. Die Störung hätte allerdings frühzeitig bemerkt werden können: Schon seit drei Wochen hatten mehrere Mitarbeiter des Unternehmens beobachtet, dass an dem RAID ein rotes Licht blinkte und hatten den IT-Manager darüber informiert. Dieser vertrat jedoch die Meinung, dass das Licht nichts zu bedeuten habe – und schliesslich gab das RAID5 die Funktion auf.

[Quelle: http://www.itmagazine.ch/Artikel/Seite/51608/4/Die_zehn_spektakulaersten_Datenverluste_2012.html]

- vergessene / verlorene Endgeräte

„London residents leave an average 10,000 mobile phones in the back of taxis every month.“

[Quelle http://www.theregister.co.uk/2009/11/30/taxi_lost_kit_survey/]

Sicherheit gegen Datenverlust bei Hardware-Ausfall

- Defekt eines Speichermediums

----- Original-Nachricht -----

Betreff: Wichtige Frage zum Praxis II-Kolloquium

Datum: Mon, 19 Aug 2013 11:15:25 +0200

Von: XXX XXX <XXX@gmail.com>

An: straub@dhbw-mannheim.de

Sehr geehrter Herr Straub,
leider ist mir während meines Praxiseinsatzes ein
Desaster passiert: **die Festplatte meines Arbeitsrechners
hatte ein Defekt** und nach dem Austausch ist
herausgekommen, dass meine **Backup-Software nicht korrekt
eingerichtet** war, sodass mein Projekt, an dem ich die
ganze Praxisphase lang gearbeitet habe, unwiederruflich
weg ist und **von der defekten Festplatte aufgrund der
Verschlüsselung keine Dateien gerettet** werden können.

...

Sicherheit gegen technische Fehler

- Programmierfehler

Montag, 28. Februar 2011

Daten sind futsch **Google verliert Mails**

Weltweit schätzungsweise 150.000 Nutzer des Email-Dienstes von Google haben aufgrund einer technischen Störung offenbar Daten  verloren. Berichten auf Internetforen zufolge meldeten Nutzer, bei ihnen seien E-Mails verschwunden. Die Google-Zentrale in Mountain View im US-Bundesstaat Kalifornien teilte mit, das Problem betreffe weniger als 0,08 Prozent der Nutzer. Experten arbeiteten an der Reparatur der Konten.

[Quelle: <http://www.n-tv.de/technik/Google-verliert-Mails-article2723376.html>]

Sicherheit gegen technische Fehler

- konzeptionelle Fehler / Missverständnisse

*„... massiven Datenverlust beim Einsatz von Ext4, dem zukünftigen Standard-Dateisystem von Linux ... **bei einem Systemabsturz kurz nach dem Laden des KDE-4-Desktops die Daten aller Dateien verloren**, in die beim Booten geschrieben wurde ...*

*... implementiert Ext4 **delayed allocation** – der zum Schreiben neuer Daten erforderliche Platz wird erst mit bis zu 60 Sekunden Verzögerung festgelegt. Das steigert die Performance und erlaubt Optimierungen der Datenorganisation auf der Platte ...*

*Eigentlich, so der Dateisystementwickler, müsste man allerdings die betroffenen Anwendungen fixen: Die **Programmierer hätten sich daran gewöhnt**, dass mit Ext3 die Zeit bis zum tatsächlichen Schreiben der Daten höchstens fünf Sekunden beträgt ...“*

[Quelle: <http://www.heise.de/newsticker/meldung/Moeglicher-Datenverlust-bei-Ext4-205664.html>]

Abgrenzung

- bisher: Sicherheit gegen Fehler im Sinne von Fehlertoleranz
- **Fokus der IT-Sicherheit liegt auf Beeinträchtigungen durch bewusste Handlungen (Angriffe) und Schutz vor diesen**
- im Englischen “safety” vs. “security”
 - **Safety** (Funktionssicherheit):
Eigenschaft eines Systems, dass realisierte **Ist-Funktionalität** der Komponenten mit spezifizierter **Soll-Funktionalität** übereinstimmt.
[Eckert, S. 6]

-> Gewährleistung der Zuverlässigkeit gegen Ausfall / Defekt,
Schutz vor unbeabsichtigten Ereignissen

Informationssicherheit – Definitionen aus ISO 27000

- Informationssicherheit ...
 - stellt **Vertraulichkeit, Verfügbarkeit und Integrität** von Information sicher.
(-> "Schutzziele", siehe unten)
 - umfasst die Anwendung und das Management von **angemessenen Sicherheitsmaßnahmen** unter Berücksichtigung einer großen Bandbreite von **Bedrohungen** mit dem Ziel, anhaltenden geschäftlichen Erfolg und einen kontinuierlichen Geschäftsbetrieb (**Business Continuity**) sicherzustellen und **Beeinträchtigungen** durch Informationssicherheitsvorfälle zu **minimieren**.
- Informationen ...
 - sind **Werte**, die [...] angemessen zu schützen sind.
 - können auf **vielfältige Weise** gespeichert werden: sowohl in *digitaler* Form, in *materieller* Form (z. B. auf Papier) als auch in nicht materieller Form als Fachwissen der Mitarbeiter.

-> es geht oft – aber nicht nur – um Sicherheit von *IT-Systemen* oder *Daten* (die Informationen auf IT-Systemen repräsentieren)

Datensicherung und Datenschutz

- **Datensicherung (backup):**

Schutz vor unbeabsichtigtem Datenverlust durch höhere Gewalt, technisches Versagen oder Fahrlässigkeit (nicht aber vorsätzliches Handeln), typischerweise realisiert durch:

- Backups der Daten (z.B. Mirroring, Tape Library, Offsite-Backup ...)
- Vorhalten von Ersatz-Hardware (Cold/Hot Standby-Systeme, Ersatz-Geräte, Ausweich-Rechenzentrum, redundante Netzanbindung ...)

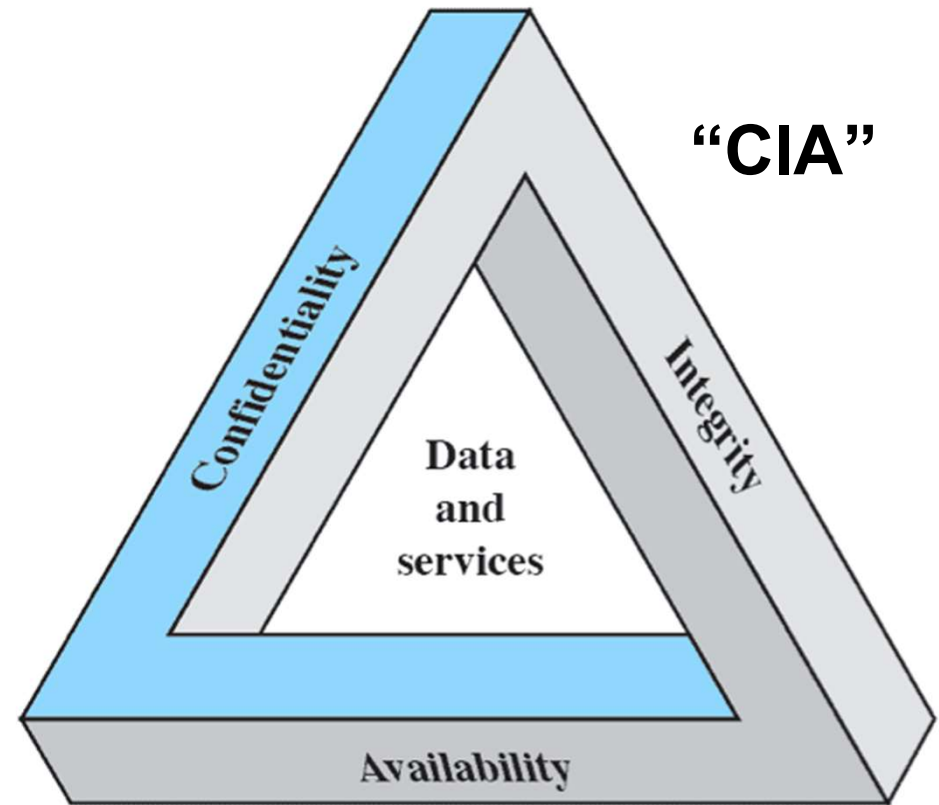
- **Datenschutz (data protection):**

bezieht sich auf personen-bezogene Daten* und den rechtlichen und technischen Schutz der betroffenen (natürlichen) Person gegen unrechtmäßige Verarbeitung

*) im Gesetz definiert als "Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person (im Folgenden „betroffene Person“) beziehen"

2. Schutzziele

- Vertraulichkeit (Confidentiality)
- Verfügbarkeit (Availability)
- Integrität (Integrity)



- Authentizität (Authenticity)
- Verbindlichkeit / Nachweisbarkeit (Non-Repudiation)
- Privatheit (Privacy)

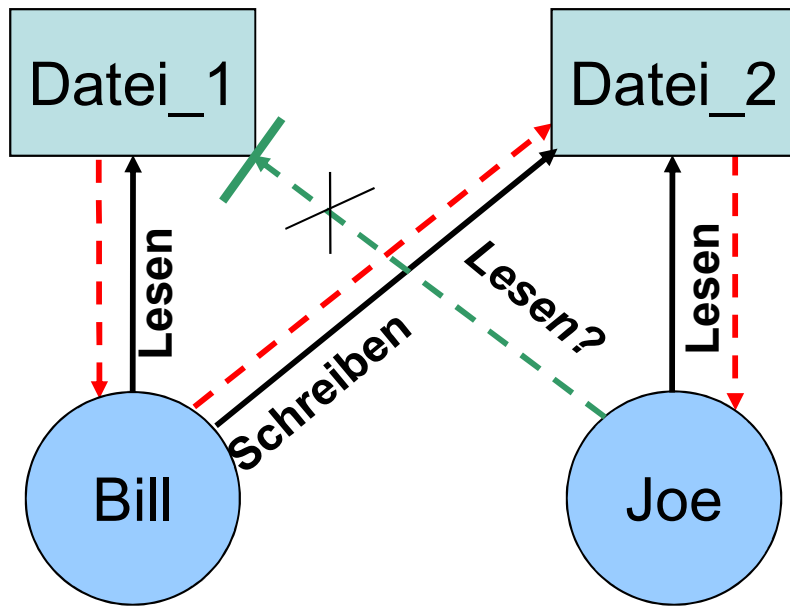
[Grafik: <http://vp8operating.blogspot.de/>]

Vertraulichkeit (Confidentiality)

- Schutz gegen **unberechtigte Kenntnissnahme** von Informationen:
 - z.B. Inhalt einer E-Mail, Geschäftsbericht, Personalakte, aber auch Metadaten, daher auch: "*Data Confidentiality*"
 - Bem: Verletzung der Vertraulichkeit nicht direkt erkennbar (z.B. passives Abhören)
- Anforderung: Festlegung und Kontrolle von **Informationsflüssen**
 - Wer (Subjekt) darf wie auf welche Informationen (Objekt) zugreifen? (z.B. Dateirechte unter Linux: r, w, x)
 - Abbildung mittels *Zugriffskontrolle (access control)*
 - *discretionary access control (DAC)*: Eigentümer entscheidet, wer Zugriff auf Objekt bekommt
 - *role-based access control (RBAC)*: Rechte werden Subjekten indirekt über Rollen zugeordnet

Beispiel: unzulässiger Informationsfluss

Betrachtung der Zugriffe auf Daten(-objekte) genügt nicht zur Kontrolle der dadurch repräsentierten Information:



-->
**effektiver Informationsfluss /
ungewollter Informationskanal**

- Objekte: Datei_1, Datei_2
 - Subjekte: Bill, Joe
 - Rechte:
 - Joe: r an Datei_2
 - Bill: w an Datei_2 und r an Datei_1
 - Forderung:
Joe darf keine Kenntnis über Informationen aus Datei_1 erlangen!
- => auf diese Weise nicht gewährleistet
Abhilfe: *mandatory access control*
(*systembestimmte Zugriffskontrolle*) mit
- Klassifizierung für Objekte (classification)
 - Freigaben für Subjekte (clearance)

Verfügbarkeit (Availability)

- Alle **Daten** sowie die zur Verarbeitung notwendigen **Systeme und Ressourcen** (z.B. Speicher, CPUs) müssen jederzeit verfügbar und funktionsbereit sein, wenn ein autorisierter Benutzer darauf zugreifen will. Dies schließt ein ...
 - Hardware, auch das Netzwerk
 - Betriebssystem und Programme
 - sowie Archive und Sicherungskopien für Daten
- Anforderung: Verfügbarkeit soll auch im Falle bestimmter (nicht aller) Angriffe noch gewährleistet sein, z.B.
 - Login für autorisierte Benutzer trotz Einbruchversuchen
 - gewisse Funktionsfähigkeit während Denial-of-Service-Angriff zur Abwehr / Schadensbegrenzung
- Verfügbarkeit oftmals schwierig (teuer) zu erreichen, Unterscheidung zwischen unautorisierten und autorisierten Aktionen nicht immer einfach (z.B. bei hoher Systemlast)

Integrität (Integrity)

- Sicherstellung der
 - **Unversehrtheit / Unverfälschtheit** von Daten oder Programmen (Datenintegrität, Data Integrity) bzw. auch
 - **korrekten Funktionsweise** von Systemen ohne beabsichtigte und unbeabsichtigte Manipulationen (Systemintegrität, System Integrity).
- Anforderung:
 - Daten dürfen nicht unautorisiert oder unbemerkt modifiziert oder gelöscht werden können.
 - Modifikationen nur gemäß festgelegter Regeln (Berechtigungen)
- Integrität kann – je nach Anwendungsfall – sogar wichtiger sein als Schutzziel der Vertraulichkeit, z.B. bei
 - Bankdaten
 - Klausurnoten
 - Logfiles
 - Betriebssystem-Funktionen etc.

Authentizität (Authenticity)

- Sicherstellung der **Echtheit**
 - **von Informationen** (Data Authenticity) mit Hilfe von *Data Authentication* (digitale Signatur, message authentication code)
 - bzw. einer behaupteten **Identität** mit Hilfe von *Entity Authentication* (mittels Passwort, Schlüssel, Biometrie, Token)
- Anforderungen:
 - Es muss sichergestellt sein, dass
 - Informationen wirklich von der angegebenen Quelle stammen bzw.
 - die vorgegebene Identität (z.B. eines Benutzers während der Kommunikation oder beim Login bzw. eines an der Kommunikation beteiligten Systems) korrekt ist.
 - Voraussetzung: eindeutige Identifikation von Subjekten und Objekten.

(Authentizität wird z.T. auch unter Integrität eingeordnet)

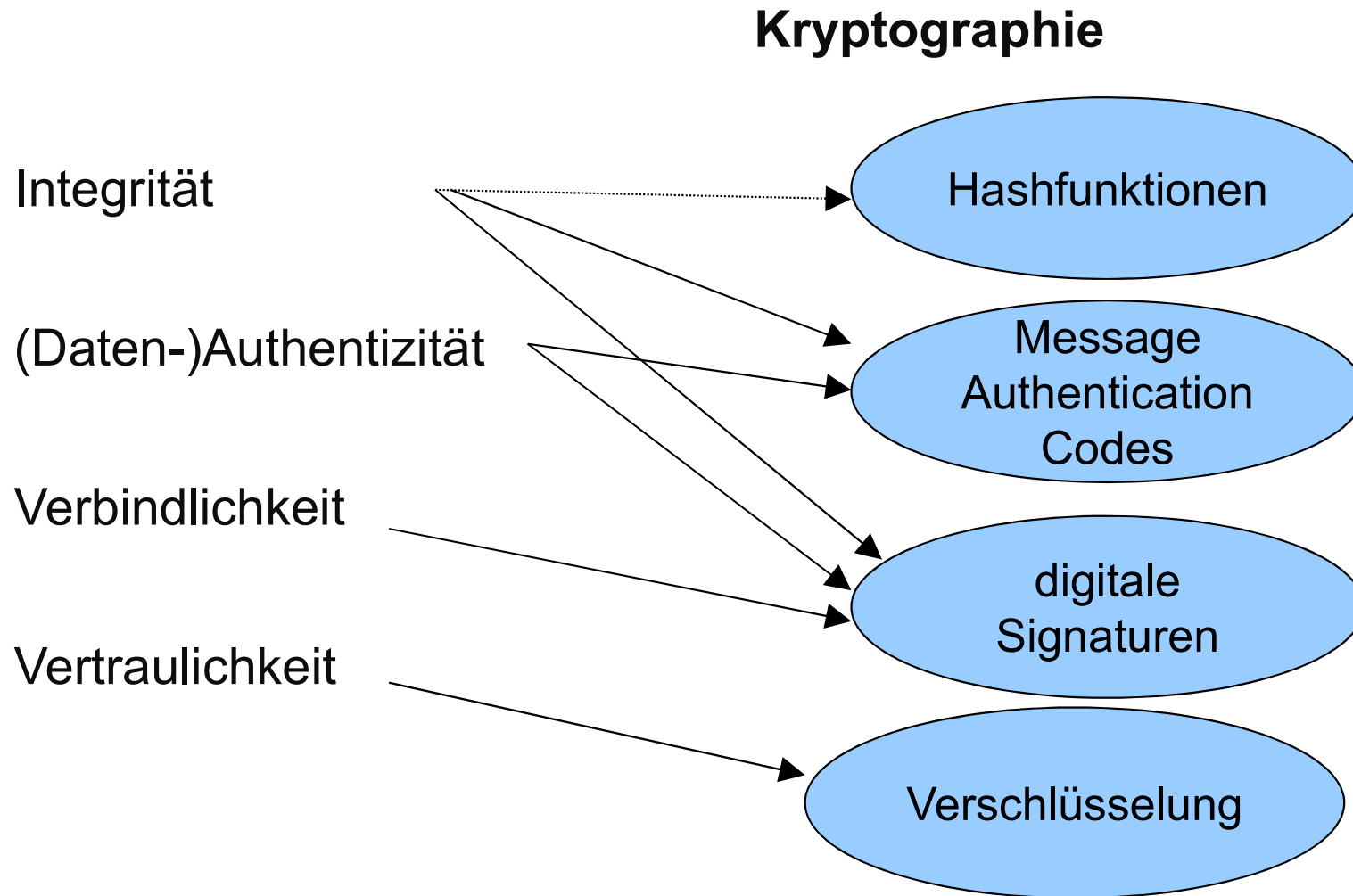
Verbindlichkeit / Nachweisbarkeit (Non-Repudiation)

- **Nachweis** für Initiieren einer Aktion oder Erzeugen eines Datums, z.B. Erstellen, Versenden und Empfang von Nachrichten
 - Anforderung: Durchgeführte Handlungen / Teilnahme von Kommunikationspartnern an einem Vorgang
 - kann nicht abgestritten werden,
 - ist Dritten gegenüber nachweisbar.
 - Nachweisbarkeit kann umfassen den Beweis ...
 - der Identität der Kommunikationspartner
 - des Vorgangs des Versendens / Zustellung / Empfang
 - weitere Umstände der Kommunikation (Dauer, Ort, Datenvolumen ...)
 - Anwendungen: Vertragsschluss im e-Commerce, Nutzung von Dienstleistungen (z.B. Cloud-Rechenzeit) -> Abrechenbarkeit (*Accountability*)
 - Mechanismen: nachvollziehbare Protokollierung (Logfiles), Forensik
- > "AAA-Systeme/-Infrastrukturen": Authentication, Authorization, Accounting, z.B. bei Netzbetreibern

Schutz der Privatsphäre (Privacy)

- Idee: Individuum soll Kontrolle über persönliche Informationen haben
- umfasst etwa
 - *Vertraulichkeit von Verbindungsdaten* (bei Telefon, E-Mail)
 - *Schutz gegen unzulässige Erhebung* (z.B. Handy-Ortung, Browser-Tracking, Verhinderung der Profilbildung/Verknüpfung von Daten bei Online-Aktivitäten)
 - *Schutz gegen unzulässige Verarbeitung und Zweckänderung* (z.B. Verkauf von Patientendaten)
- Möglichkeiten zum Schutz:
 - technisch: z.B. Anonymisierung, Verschlüsselung
 - organisatorisch: z.B. Berechtigungskonzept
 - rechtlich: Datenschutzrecht, Grundrecht auf „informationelle Selbstbestimmung“

Kryptographische Methoden zur Umsetzung der Schutzziele



Wiederholung Kryptographie: siehe separater Foliensatz

3. ■ Schwachstellen und Angriffe [Eckert]

- **Schwachstelle** (engl. Weakness):
(prinzipbedingte) allgemeine Schwäche eines Systems oder ein Punkt, an dem das System verwundbar werden kann; Bsp:
 - jegliche Hardware – natürliche Schwachstelle: Naturkatastrophen
 - mobile Geräte – physische Schwachstelle: Diebstahlgefahr
 - WLAN – Schwachstelle: Störung oder Abhören der Funksignale
 - Software – Schwachstelle: Progr.fehler, fehlende Eingabeprüfung
- **Verwundbarkeit** (engl. Vulnerability):
spezifische Schwäche, über die Sicherheitsdienste des Systems umgangen, getäuscht oder unautorisiert modifiziert werden können; Bsp:
 - Programmierfehler führen zu Verwundbarkeit durch Buffer Overflows
- Bem: oftmals keine Unterscheidung: *vulnerability – A flaw or weakness in a system's design, implementation, or operation and management that could be exploited to violate the system's security policy.*
[\[RFC4949: Internet Security Glossary\]](#)

Bedrohung, Risiko, Asset

- **Bedrohung** (threat):
 - potentielle Sicherheitsverletzung durch Ausnutzung einer Schwachstelle (um ein Sicherheitsziel zu gefährden)
 - *“a potential for violation of security, which exists when there is an entity, circumstance, capability, action, or event that could cause harm.”* [RFC4949]
- **Risiko** (risk):

Wahrscheinlichkeit, dass Schadensereignis (E) eintritt und Höhe des dadurch hervorgerufenen Schadens (S), erwarteter Schaden $R = E * S$
- **Asset** (wert):

schützenswertes Gut (Information, Daten-Objekt) eines Systems

Angriff (attack)

- nicht autorisierter Zugriff/Zugriffsversuch auf das System/ein Asset
„An intentional act by which an entity attempts to evade security services and violate the security policy of a system.“ [RFC4949]
 - **passiver Angriff** -> unautorisierte Informationsgewinnung, z.B. Netzwerkverkehr abhören (Sniffen)
 - **aktiver Angriff** -> unautorisierte Modifikation von Objekten, z.B. Maskierung (Spoofing), d.h. Vorgeben einer falschen Identität (E-Mail-Adresse spoofen, DNS-Antwort ...), Denial-of-Service (DoS)
- **Angriffsvektor** (attack vector):
Methode oder Typ eines Angriffs
- **Exploit**:
systematische Möglichkeit (i.d.R. Programmcode), um eine Schwachstelle für einen Angriff auszunutzen

Cyber Kill Chain [Hutchins et al. 2011]

1. **Identifizierung potenzieller Ziele** und deren Eigenschaften / Schwachstellen
2. **Toolvorbereitung** (z.B. mit Malware präparierte DOC-Datei, Trojaner)
3. **Einschleusen** in System des Opfers
4. **Ausnutzen der Schwachstelle**, um Zugang zu System zu erhalten und sich dort zu bewegen
5. **Installation**, z.B. Backdoors, Anpassung Konfigurationen/Berechtigungen
6. Verbindung zu **Command & Control-Server** herstellen
7. **Umsetzung eigentlicher Ziele**, etwa Datendiebstahl, Verschlüsselung, Angriff auf weitere Systeme

[Grafik: <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>]



Wer sind die Angreifer? 1. Einzeltäter

- *Innentäter*, d.h. krimineller, frustrierter, eingeschleuster Mitarbeiter
-> Anteil an Innentätern wird als relativ hoch eingeschätzt, Schadenspotential erhöht im Vgl. zu Außentäter, da mehr Kenntnisse der IT-Systeme und bereits gewisse Berechtigungen
- *Hacker*: technisch versiert, will Schwachstellen entdecken und publik machen, um auf sie aufmerksam zu machen (auch: "White Hat")
- *Cracker*: wie Hacker, allerdings krimineller Energie. Interesse an finanziellem Vorteil oder Schädigung des Opfers (auch: "Black Hat")
- „*Script-Kiddie*“: geringes technisches Verständnis, unbedarf, „spielt“ mit Exploits (= Software, die Verwundbarkeiten ausnutzt) anderer

Ermittlungen: Apotheker-Lobbyist soll Gesundheitsministerium ausspioniert haben

Der Einfluss der deutschen Apothekerschaft auf politische Entscheidungen galt immer schon als besonders groß. Nun ermittelt die Staatsanwaltschaft: Über Jahre soll sich ein Lobbyist Daten aus dem Gesundheitsministerium verschafft haben - auch Mails der Minister Rösler und Bahr. (2012)

2. Organisationen

Erpresser haben Nackt-Chatter im Visier

Ein neue Masche von Internetkriminalität hat in Neuseeland erste Opfer gefunden: Computernutzer, die sich über ihre Webcams nackt mit anderen Nutzern unterhielten, erhielten im Anschluss Erpresser-Mails.

- *Unternehmen*, die Nutzerdaten sammeln und auswerten, z.B.
 - Android: Standort an Google geschickt (auch ohne SIM und deaktiviertem GPS, per Cell-IDs) [<https://qz.com/1131515/>]
 - Web-/App-Tracking: Facebook, Google Analytics, Bibliotheken
- *(organisierte) Kriminalität*: Phishing, Ransomware, Erpressung
- *Cyber-Terroristen* (2015: Islamisten legen Sender TV5 Monde lahm)
- *Strafverfolgungsbehörden, Geheimdienste*:
 - Industriespionage (z.B. PRISM, Tempora, Echelon ...),
 - „Bundestrojaner“, Vorratsdatenspeicherung ...
 - Cyberwar: Stromausfall bei ukrainischem Stromversorger (2015), Hackerangriffe auf Bundestag (2015, 2021)

[Quelle: <http://www.wlzfz.de/Welt/Medien/UEbersicht/Internetkriminalitaet-User-in-Neuseeland-erhalten-Erpresser-Mails-nach-Nackt-Chatten>]

Aktuelle Bedrohungen

Figure 1: ENISA Threat Landscape 2022 - Prime threats



Erläuterungen



- **Ransomware:** Lösegeld-Erpressung durch Lahmlegen von Systemen / Verschlüsselung von Daten
- **Malware:** Schadsoftware (Computerviren, Trojanische Pferde)
- **Social Engineering:** Ausnutzen menschlicher Fehler/Schwächen durch psychologische Manipulation und Tricks (z.B. Phishing)
- **Threats against data:** „data breach“ = Verletzung des Schutzes pb Daten
eine Verletzung der Sicherheit, die, ob unbeabsichtigt oder unrechtmäßig, zur Vernichtung, zum Verlust, zur Veränderung, oder zur unbefugten Offenlegung von beziehungsweise zum unbefugten Zugang zu personenbezogenen Daten führt, die übermittelt, gespeichert oder auf sonstige Weise verarbeitet wurden; (Art. 4 Nr. 12 DS-GVO)
- **Threats against availability:**
Denial of Service (DoS): System oder Netzwerk wird gezielt überlastet
- **Threats against availability: Internet threats:** Unterbrechungen der Kommunikation, zB. durch Naturkatastrophen, Cyber- oder militärische Angriffe
- **Information Manipulation:** Desinformation und Propaganda durch staatliche oder nicht-staatliche Akteure
- **Supply Chain Attacks:** „Lieferkettenangriffe“, bei denen nicht nur eigentliches Ziel, sondern zuvor Dritter angegriffen wird, z.B. über Software-Komponenten oder Werkzeuge

4.

Schutzmaßnahmen

- **Schutzmaßnahme** (countermeasure, control)
„An action, device, procedure, or technique that meets or opposes (i.e., counters) a threat, a vulnerability, or an attack by eliminating or preventing it, by minimizing the harm it can cause, or by discovering and reporting it so that corrective action can be taken.“ [RFC4949]
- Verschiedene Ansätze nach [Pfleeger]:
Angriff ...
 - verhindern (prevent)
 - erschweren (deter)
 - auf ein anderes (leichteres) Ziel umlenken, z.B. Honeypot (deflect)
 - erkennen (detect)
 - Wiederherstellung/Schadensbegrenzung (recover)
- zu ergänzen: reagieren (response)
[Stallings]

PREVENT



DETER



DETECT



DEFLECT



RECOVER



RESPONSE



Kategorisierung und Beispiele

	Prävention	Detektion	Reaktion
organisatorische Schutzmaßnahmen	Awareness-Kampagnen Schulungen	Regelungen zur Logfile-Auswertung	CERT * Notfall-Plan
technische Schutzmaßnahmen	Firewall Virens Scanner	Intrusion Detection System Virens Scanner	Intrusion Prevention System Virens Scanner

*) CERT = Computer Emergency Response Team,
auch: Computer Security Incident Response Team (CSIRT)

Defense in depth (auch: Layering)

- militärisches Konzept, einen Angriff zu verzögern
- Idee: mehrere Schichten von Schutzmaßnahmen gegen äußere Bedrohungen, die Angriff verhindern bzw. ihn detektieren und seine Auswirkungen verzögern, so dass Zeit bleibt, Gegenmaßnahmen zu ergreifen

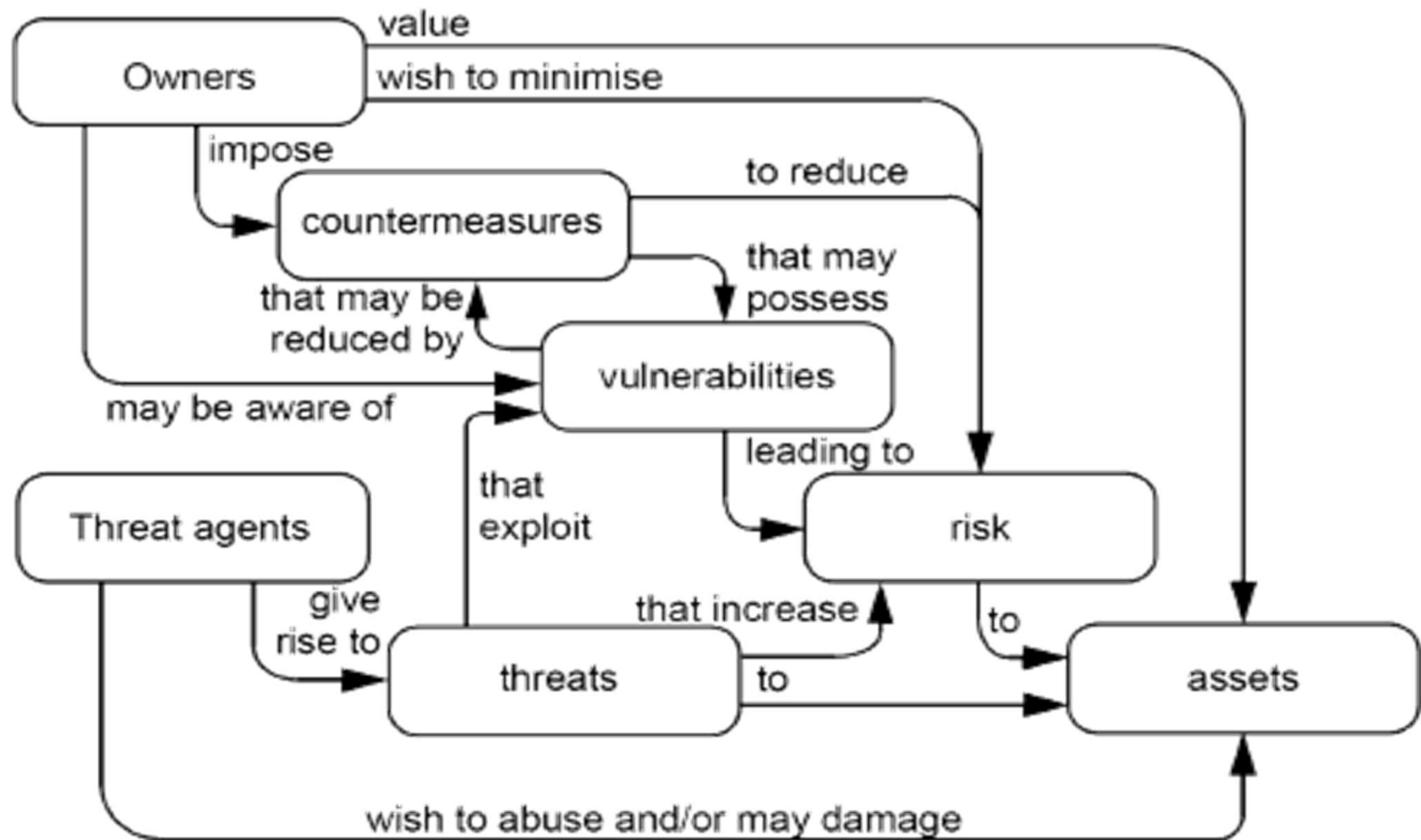
*In information systems, defense in depth means constructing a system's security architecture **with layered and complementary security mechanisms** and countermeasures, so that if one security mechanism is defeated, one or more other mechanisms (which are "behind" or "beneath" the first mechanism) still provide protection. [RFC4949]*

- nicht gemeint: mehrere gleichartige Werkzeuge (z.B. zwei Virens Scanner),
- sondern Redundanz, so dass Angreifer verschiedene Barrieren überwinden muss

Defense in depth – Beispiele

- *Perimeter-Schutz* für's Netzwerk: Firewall, IDS/IPS, Load Balancing
- *Network-based IDS*: Erkennung von Anomalien oder spez. Angriffen
- *Netzwerk-Segmentierung*: Filterung an den Übergängen, im Notfall Trennung des Netzwerks, erschwert Angriffe aus dem internen Netz
- *Separieren von Diensten*: nur ein Dienst pro (physischem/virtuellen) Server, z.B. Multi-Tier-Architektur
- *System-Härtung* (z.B. Löschen nicht benötigter User-Accounts, restriktive Berechtigungen, Sandboxing), *Patch-Management*
- *Host-basiertes IDS, Logging*
- *Applikations-spezifische Maßnahmen* (z.B. Web-Application Firewall)
- *Personal*: orga. Maßnahmen, Sicherheitsmanagement, Policies, Awareness
- *Disaster Recovery, Business Continuity Planing, forensische Analysen*

Zusammenspiel



[Quelle: [Common Criteria for Information Technology Security Evaluation](#)]

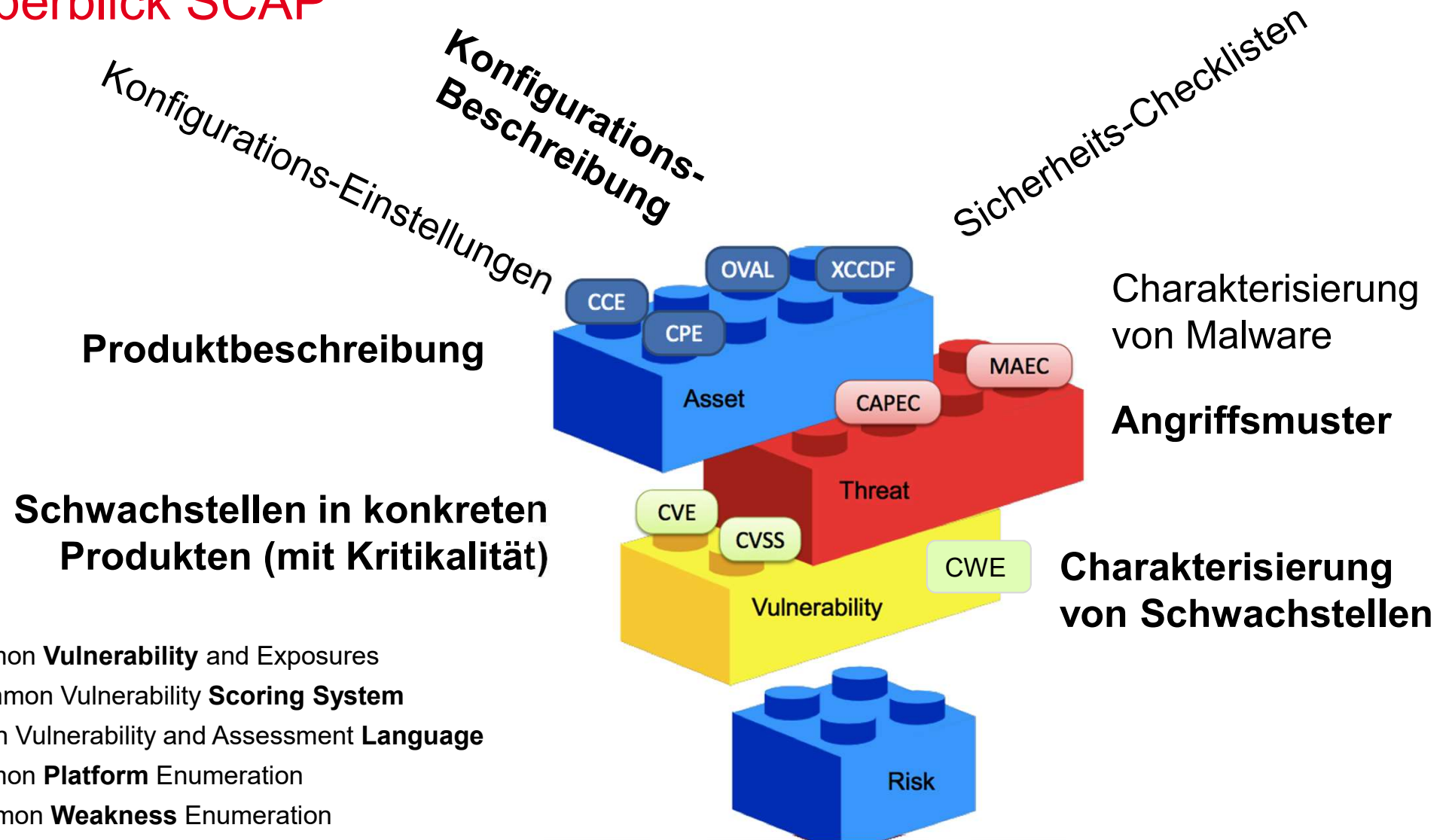
5. ■ Schwachstellen-Systematisierung und -Management

- Wie lässt sich IT-Sicherheit „managen“ ?

Anforderungen:

- *Überblick behalten* über Vielzahl eingesetzter Systeme
 - *schnelle Reaktion* auf Sicherheitsvorfälle
 - *Compliance*: Maßnahmen müssen dokumentiert werden
 - *Verständlichkeit* durch einheitliche Terminologie, einheitliche Metriken (Hersteller-übergreifend)
-
- Bsp.: **Security Content Automation Protocol (SCAP)** aus verschiedenen offenen Standards – Einsatzmöglichkeiten:
 - automatische Überprüfung auf Verwundbarkeiten
 - automatisches Verifizieren von Konfigurations-Einstellungen
 - Berichtswesen
 - Priorisierung von Gegenmaßnahmen

Überblick SCAP



CVE: Common **Vulnerability** and Exposures

CVSS: Common Vulnerability **Scoring System**

OVAL: Open Vulnerability and Assessment **Language**

CPE: Common **Platform** Enumeration

CWE: Common **Weakness** Enumeration

CAPEC: Common **Attack Pattern** Enumeration and Classification

MAEC: **Malware** Attribute Enumeration and Characterization

CCE: Common **Configuration** Enumeration

XCCDF: eXtensible **Configuration Checklist** Description Format

[Grafik: R. Gandhi]
mit Erweiterung CWE

Common Vulnerabilities and Exposures



a dictionary of publicly known information security vulnerabilities and exposures#. CVE's common identifiers enable data exchange between security products and provide a baseline index point for evaluating coverage of tools and services.*

- neu gefundene Schwachstellen werden mit eindeutiger ID bezeichnet
- Liste: National Vulnerability Database: <https://nvd.nist.gov/>
- referenziert von CERTs oder anderen DBs „TOP50“-Liste: <https://www.cvedetails.com/top-50-products.php>

* Vulnerability is a state in which an object can **potentially** be affected (Verwundbarkeit)

Exposure is a state in which an object is **already** being affected by a force (Ausgesetztsein)

Adobe Security Bulletin

Security updates available for Adobe Flash Player

Release date: July 12, 2016

Vulnerability identifier: APSB16-25

Priority: See table below

CVE number: CVE-2016-4172, CVE-2016-4173, CVE-2016-4174, CVE-2016-4175, CVE-2016-4176, CVE-2016-4177, CVE-2016-4178, CVE-2016-4179, CVE-2016-4180, CVE-2016-4181, CVE-2016-4182, CVE-2016-4183, CVE-2016-4184, CVE-2016-4185, CVE-2016-4186, CVE-2016-4187, CVE-2016-4188, CVE-2016-4189, CVE-2016-4190, CVE-2016-4217, CVE-2016-4218, CVE-2016-4219, CVE-2016-4220, CVE-2016-4221, CVE-2016-4222, CVE-2016-4223, CVE-2016-4224, CVE-2016-4225, CVE-2016-4226, CVE-2016-4227, CVE-2016-4228, CVE-2016-4229, CVE-2016-4230, CVE-2016-4231, CVE-2016-4232, CVE-2016-4233, CVE-2016-4234, CVE-2016-4235, CVE-2016-4236, CVE-2016-4237, CVE-2016-4238, CVE-2016-4239, CVE-2016-4240, CVE-2016-4241, CVE-2016-4242, CVE-2016-4243, CVE-2016-4244, CVE-2016-4245, CVE-2016-4246, CVE-2016-4247, CVE-2016-4248, CVE-2016-4249

Platform: Windows, Macintosh, Linux and ChromeOS

Common Vulnerability Scoring System



- standardisierte Metrik zur Bewertung von
 - Kritikalität einer Schwachstelle und
 - Schwierigkeitsgrad für Angreifer zur Ausnutzung mit dem Ziel,
 - Relevanz (Risiko) für eigene IT-Umgebung zu bewerten und
 - Gegenmaßnahmen zu priorisieren
- Details und Bsp: siehe unten
- mehrere Versionen in Gebrauch:
 - v4.0: hier beschrieben
 - Vorgänger: v3.1/3.0 und v2.0
 - liefern jeweils Schweregrad zwischen 0 und 10
 - Spezifikationen: <https://www.first.org/cvss/>

Open Vulnerability and Assessment Language



- XML-Beschreibungssprache, ermöglicht systemübergreifenden Austausch, Community: [<https://oval.cisecurity.org/>]
- beschreibt Systemkonfigurationen, unter denen Schwachstelle auftritt

🚩 CVE-2013-2556 Detail

MODIFIED

This vulnerability has been modified since it was last analyzed by the NVD. It is awaiting reanalysis which may result in further changes to the information provided.

Current Description

Unspecified vulnerability in Microsoft Windows Vista SP2, Windows Server 2008 SP2 and R2 SP1, and Windows 7 through SP1 allows attackers to bypass the ASLR protection mechanism via unknown vectors, as demonstrated against Adobe Flash Player by VUPEN during a Pwn2Own competition at CanSecWest 2013, aka "ASLR Security Feature Bypass Vulnerability."

Vulnerable software and versions [Switch to CPE 2.3](#)

Configuration 1

OR

* [cpe:/o:microsoft:windows_vista::sp2](#)

* [cpe:/o:microsoft:windows_vista::sp2:x64](#)

Configuration 2

OR

* [cpe:/o:microsoft:windows_7::-sp1:x64](#)

* [cpe:/o:microsoft:windows_7::-sp1:x86](#)

Configuration 3

OR

* [cpe:/o:microsoft:windows_server_2008::sp2:itanium](#)

-> Komponenten per CPE beschrieben (s.u.)

Common Platform Enumeration



- standardisiertes Namensformat (URI-Syntax), [<https://nvd.nist.gov/products/cpe>]

cpe:/ {part} : {vendor} : {product} : {version} : {update} : {edition} : {language}

(Version 2.2)

zur eindeutigen Bezeichnung von Komponenten der

- Hardware (part: „h“)
- Betriebssystemen („o“)
- Anwendungen („a“)

CPE Dictionary

<https://nvd.nist.gov/products/cpe>

- kann zur Aufzählung von Assets im Unternehmen genutzt werden, z.B.

192.168.181.34|cpe:/a:openssl:openssl:0.9.8e:e

192.168.181.34|cpe:/a:gnu:gzip:1.3.5

192.168.181.34|cpe:/o:centos:centos:5

192.168.181.1|cpe:/h:cisco:adaptive_security_appliance:7.1

Common Weakness Enumeration



- Systematik zur Beschreibung und Klassifikation von Schwachstellen
- Art der Schwachstelle wird bei CVE-Eintrag angegeben, z.B. Buffer Errors (CWE-119) [<http://cwe.mitre.org/data/definitions/119.html>]

CWE-119: Improper Restriction of Operations within the Bounds of a Memory Buffer

Improper Restriction of Operations within the Bounds of a Memory Buffer	
Weakness ID: 119 (Weakness Class)	Status: Usable
► Description	
► Alternate Terms	
► Time of Introduction	
► Applicable Platforms	
► Common Consequences	
► Likelihood of Exploit	
► Detection Methods	
► Demonstrative Examples	
► Observed Examples	
► Potential Mitigations	
► Relationships	
► Affected Resources	
► Taxonomy Mappings	
► Related Attack Patterns	
► References	
► Content History	

Related Attack Patterns		
CAPEC-ID	Attack Pattern Name	(CAPEC Version: 2.8)
CAPEC-10	Buffer Overflow via Environment Variables	
CAPEC-100	Overflow Buffers	
CAPEC-14	Client-side Injection-induced Buffer Overflow	
CAPEC-24	Filter Failure through Buffer Overflow	
CAPEC-42	MIME Conversion	
CAPEC-44	Overflow Binary Resource File	
CAPEC-45	Buffer Overflow via Symbolic Links	
CAPEC-46	Overflow Variables and Tags	
CAPEC-47	Buffer Overflow via Parameter Expansion	
CAPEC-8	Buffer Overflow in an API Call	
CAPEC-9	Buffer Overflow in Local Command-Line Utilities	

zugeordnete Angriffsvektoren (s.u.)

CWE – Systematik der Beschreibung

- hierarchische Systematik mit Klassen und Kategorien

[Quelle: <https://cwe.mitre.org>]

Ⓒ Weakness Class – A weakness that is described in a very abstract fashion, typically independent of any specific language or technology. It is more general than a Base weakness.

Ⓑ Weakness Base – A weakness that is described in an abstract fashion, but with sufficient details to infer specific methods for detection and prevention. It is more general than a Variant weakness, but more specific than a Class weakness.

Ⓥ Weakness Variant – A weakness that is described at a very low level of detail, typically limited to a specific language or technology. It is more specific than a Base weakness.

Ⓒ Compound Element Composite – An entry that consists of two or more distinct weaknesses, in which all weaknesses must be present at the same time in order for a potential vulnerability to arise. Removing any of the weaknesses eliminates or sharply reduces the risk.

Ⓒ Category – A CWE entry that contains a set of other entries that share a common characteristic.

Ⓥ View – A subset of CWE entries that provides a way of examining CWE content. The two main View Structures are Slices (flat lists) and Graphs (containing relationships between entries).

↑ allgemeiner
↓ konkreter

699 - Development Concepts

- ⊕ **C** Location - (1)
- ⊕ **C** Motivation/Intent - (504)
- ⊖ **V** Resource-specific Weaknesses - (631)
 - ⊖ **C** Weaknesses that Affect Files or Directories - (632)
 - **V** Creation of chroot Jail Without Changing Working Directory - (243)
 - **B** Files or Directories Accessible to External Parties - (552)
 - **C** Improper Access Control - (284)
 - **B** Improper Control of Filename for Include/Require Statement in PHP Program ('PHP Remote File Inclusion') - (98)
 - **B** Improper Handling of Case Sensitivity - (178)
 - **V** Improper Handling of Windows Device Names - (67)
 - **C** Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') - (22)
 - **B** Improper Link Resolution Before File Access ('Link Following') - (59)
 - **B** Improper Neutralization of Directives in Statically Saved Code ('Static Code Injection') - (96)
 - **C** Improper Ownership Management - (282)
 - **B** Improper Resolution of Path Equivalence - (41)
 - **V** Information Exposure Through Server Log Files - (533)
 - ⊕ **C** Mac Virtual File Problems - (70)
 - **V** Password in Configuration File - (260)

[Quelle: <http://cwe.mitre.org/data/graphs/699.html>]

CWE-260: Password in Configuration File

Password in Configuration File

Weakness ID: 260 (*Weakness Variant*)

Status: Incomplete

▼ Description

Description Summary

The software stores a password in a configuration file that might be accessible to [actors](#) who do not know the password.

Extended Description

This can result in compromise of the system for which the password is used. An [attacker](#) could gain access to this file and learn the stored password or worse yet, change the password to one of their choosing.

▼ Time of Introduction

- Architecture and Design
- Implementation

▼ Applicable Platforms

Languages

All

▼ Common Consequences

Scope	Effect
Access Control	Technical Impact: Gain privileges / assume identity

▼ Demonstrative Examples

Example 1

Below is a snippet from a Java properties file in which the LDAP server password is stored in plaintext.

Example Language: **Java**

(Bad Code)

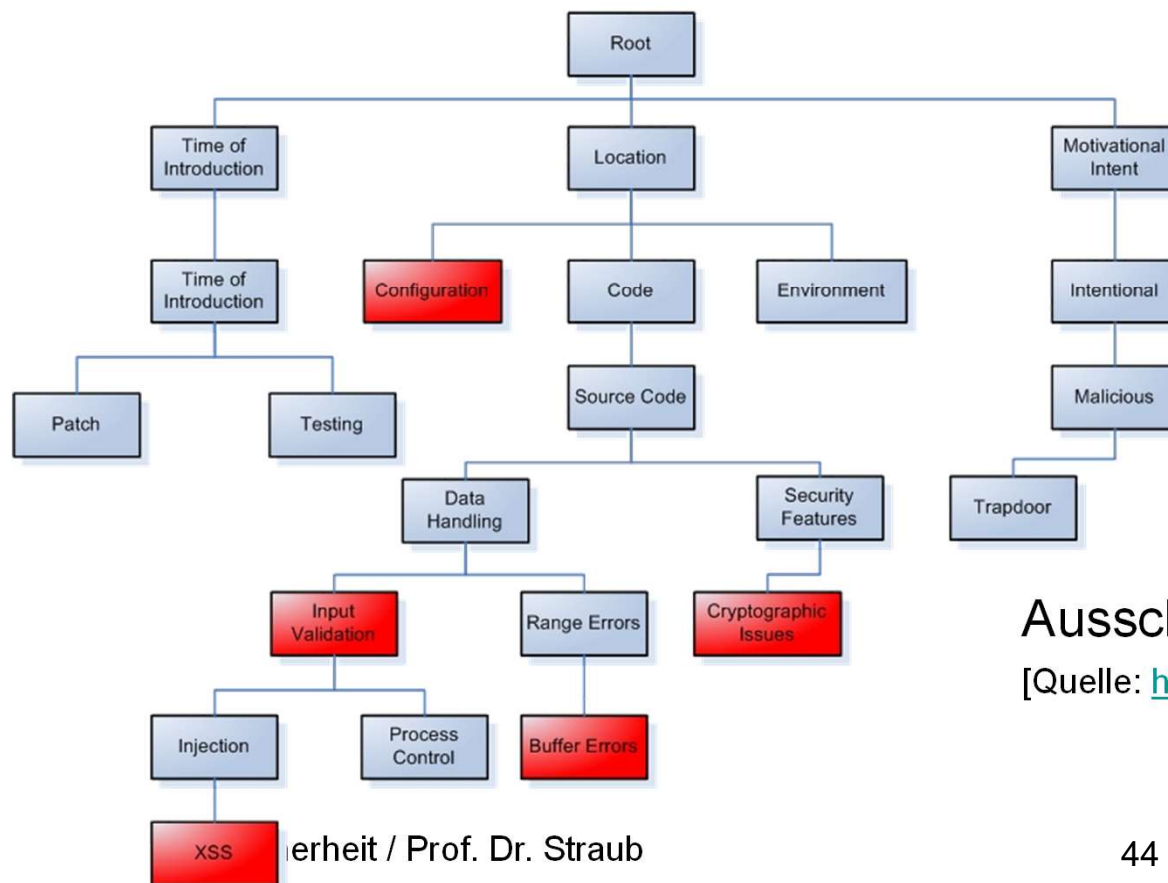
```
webapp.ldap.username=secretUsername  
webapp.ldap.password=secretPassword
```

[Quelle: <http://cwe.mitre.org/data/definitions/260.html>]

CWE-260: Password in Configuration File

▼ Relationships				
Nature	Type	ID	Name	V
ChildOf	C	254	<u>Security Features</u>	699 700
ChildOf	B	522	<u>Insufficiently Protected Credentials</u>	699 1000
ChildOf	C	632	<u>Weaknesses that Affect Files or Directories</u>	631
ChildOf	C	895	<u>SFP Cluster: Information Leak</u>	888
ParentOf	V	13	<u>ASP.NET Misconfiguration: Password in Configuration File</u>	1000
ParentOf	V	258	<u>Empty Password in Configuration File</u>	699 1000

Portion of CWE Structure



Ausschnitt aus Baumstruktur

[Quelle: <https://nvd.nist.gov/cwe.cfm> - cwes]

Common Attack Pattern Enumeration and Classification (CAPEC)

- Perspektive des Angreifers („know your enemy“)
- einheitliches Vokabular und Liste bekannter Angriffsvektoren
- Bsp: [<http://capec.mitre.org/data/definitions/248.html>]

CAPEC-248: Command Injection

Attack Pattern ID: 248
Abstraction: Meta

Status: Draft
Completeness: Hook

Presentation Filter: Basic

Attack Prerequisites

- The target application must accept input from the user. In virtually all cases, this must be string input.
- The target application must fail to adequately filter the user input against the insertion of instructions.

Related Attack Patterns

Nature	Type	ID	Name	V
ParentOf	S	66	SQL Injection	1000
ParentOf	S	88	OS Command Injection	1000
ParentOf	S	136	LDAP Injection	1000

- **MAEC** (Malware Attribute Enumeration and Characterization): standardisierte Charakterisierung von Malware anhand von Fähigkeiten und Verhaltensmustern: <https://maecproject.github.io>

ATT&CK-Framework Adversarial Tactics, Techniques & Common Knowledge

- Techniken für Phasen, die bei Angriff durchlaufen werden

14 Taktiken = Ziele des Angreifers

...							
Reconnaissance 10 techniques	Resource Development 8 techniques	Initial Access 9 techniques	Execution 14 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 42 techniques	Credential Access 17 techniques
Active Scanning (0/3)	Acquire Access	Drive-by Compromise	Cloud Administration Command	Account Manipulation (0/5)	Abuse Elevation Control Mechanism (0/4)	Abuse Elevation Control Mechanism (0/4)	Adversary-in-the-Middle (0/3)
Gather Victim Host Information (0/4)	Acquire Infrastructure (0/8)	Exploit Public-Facing Application	Command and Scripting Interpreter (0/9)	BITS Jobs	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (0/4)
Gather Victim Identity Information (0/3)	Compromise Accounts (0/3)	External Remote Services	Container Administration Command	Boot or Logon Autostart Execution (0/14)	Boot or Logon Autostart Execution (0/14)	BITS Jobs	Credentials from Password Stores (0/5)
Gather Victim Network Information (0/6)	Compromise Infrastructure (0/7)	Hardware Additions	Deploy Container	Boot or Logon Initialization Scripts (0/5)	Boot or Logon Initialization Scripts (0/5)	Build Image on Host	Exploitation for Credential Access
Gather Victim Org Information (0/4)	Develop Capabilities (0/4)	Phishing (0/3)	Exploitation for Client Execution	Browser Extensions	Create or Modify System Process (0/4)	Debugger Evasion	Forced Authentication
Phishing for Information (0/3)	Establish Accounts (0/3)	Replication Through Removable Media	Inter-Process Communication (0/3)	Compromise Client Software Binary	Domain Policy Modification (0/2)	Deobfuscate/Decode Files or Information	Forge Web Credentials (0/2)
Search Closed Sources (0/2)	Obtain Capabilities (0/6)	Supply Chain Compromise (0/3)	Native API	Create Account (0/3)	Escape to Host	Deploy Container	Input Capture (0/4)
Search Open Technical Databases (0/5)	Stage Capabilities (0/6)	Trusted Relationship	Scheduled Task/Job (0/5)	Create or Modify System Process (0/4)	Event Triggered Execution (0/16)	Direct Volume Access	Modify Authentication Process (0/8)
Search Open Websites/Domains (0/3)		Valid Accounts (0/4)	Serverless Execution	Event Triggered Execution (0/16)	Exploitation for Privilege Escalation	Domain Policy Modification (0/2)	Multi-Factor Authentication Interception
Search Victim-Owned Websites			Shared Modules	External Remote Services	Hijack Execution Flow (0/12)	Execution Guardrails (0/1)	Multi-Factor Authentication Request Generation
			Software Deployment Tools	Hijack Execution Flow (0/12)	Process	Exploitation for Defense Evasion	
			System Services (0/2)			File and Directory Permissions Modification (0/2)	
						Hide Artifacts (0/10)	

196 Techniken (mit 411 Sub-Techniken):

wie kann Ziel erreicht werden

Procedure Examples: Beispiele, Anwendungsfälle

<https://attack.mitre.org>

Beispiel CVE-Eintrag (mitre.org)

enthält:

- **CVSS-Score:**
Vektor mit Voraussetzungen und Auswirkungen
- **OVAL-Beschreib.**
betroffener Systeme, Verwendung von CPE
- **CWE-Typ** der Schwachstelle

National Cyber Awareness System
Vulnerability Summary for CVE-2013-1705
Original release date: 08/07/2013
Last revised: 08/09/2013
Source: US-CERT/NIST

Overview
Heap-based buffer underflow in the cryptojs_interpret_key_gen_type function in Mozilla Firefox before 23.0 and SeaMonkey before 2.20 allows remote attackers to execute arbitrary code or cause a denial of service (application crash) via a crafted Certificate Request Message Format (CRMF) request.

Impact
CVSS Severity (version 2.0):
CVSS v2 Base Score: 10.0 (HIGH) (AV:N/AC:L/Au:N/C:C/I:C/A:C) (legend)
Impact Subscore: 10.0
Exploitability Subscore: 10.0
CVSS Version 2 Metrics:
Access Vector: Network exploitable
Access Complexity: Low
Authentication: Not required to exploit
Impact Type: Allows unauthorized disclosure of information; Allows unauthorized modification; Allows disruption of service

References to Advisories, Solutions, and Tools
By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inference should be drawn as to the accuracy of the information being referred to.

Vulnerable software and versions
Configuration 1
OR
* [cpe:/a:mozilla:seamonkey:2.18:beta1](#)
* [cpe:/a:mozilla:seamonkey:2.20:beta3](#) and previous versions
* [cpe:/a:mozilla:seamonkey:2.20:beta2](#)
* [cpe:/a:mozilla:seamonkey:2.20:beta1](#)

Technical Details
Vulnerability Type (View All)
Buffer Errors (CWE-119)
CWE Standard Vulnerability Entry: <http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2013-1705>

Beispiel CVE-Eintrag (nvd.nist.gov)

CVSS-Score:

- kann sich je nach Quelle auch unterscheiden
- z.T. sind Vulnerabilities noch nicht bewertet, Metadaten fehlen
[\[https://heise.de/-9826196\]](https://heise.de/-9826196)

CVE-2024-13039 Detail

Description

A vulnerability was found in code-projects Simple Chat System 1.0. It has been rated as critical. Affected by this issue is some unknown functionality of the file /add_user.php. The manipulation of the argument name/email/password/number leads to sql injection. The attack may be launched remotely. The exploit has been disclosed to the public and may be used.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 8.8 HIGH

Vector:

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H



CNA: VulDB

Base Score: 6.3 MEDIUM

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

References to Advisories, Solutions, and Tools

Weakness Enumeration

CWE-ID	CWE Name	Source
CWE-74	Improper Neutralization of Special Elements in Output Used by a Downstream Component ('Injection')	NIST VulDB
CWE-89	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	NIST VulDB

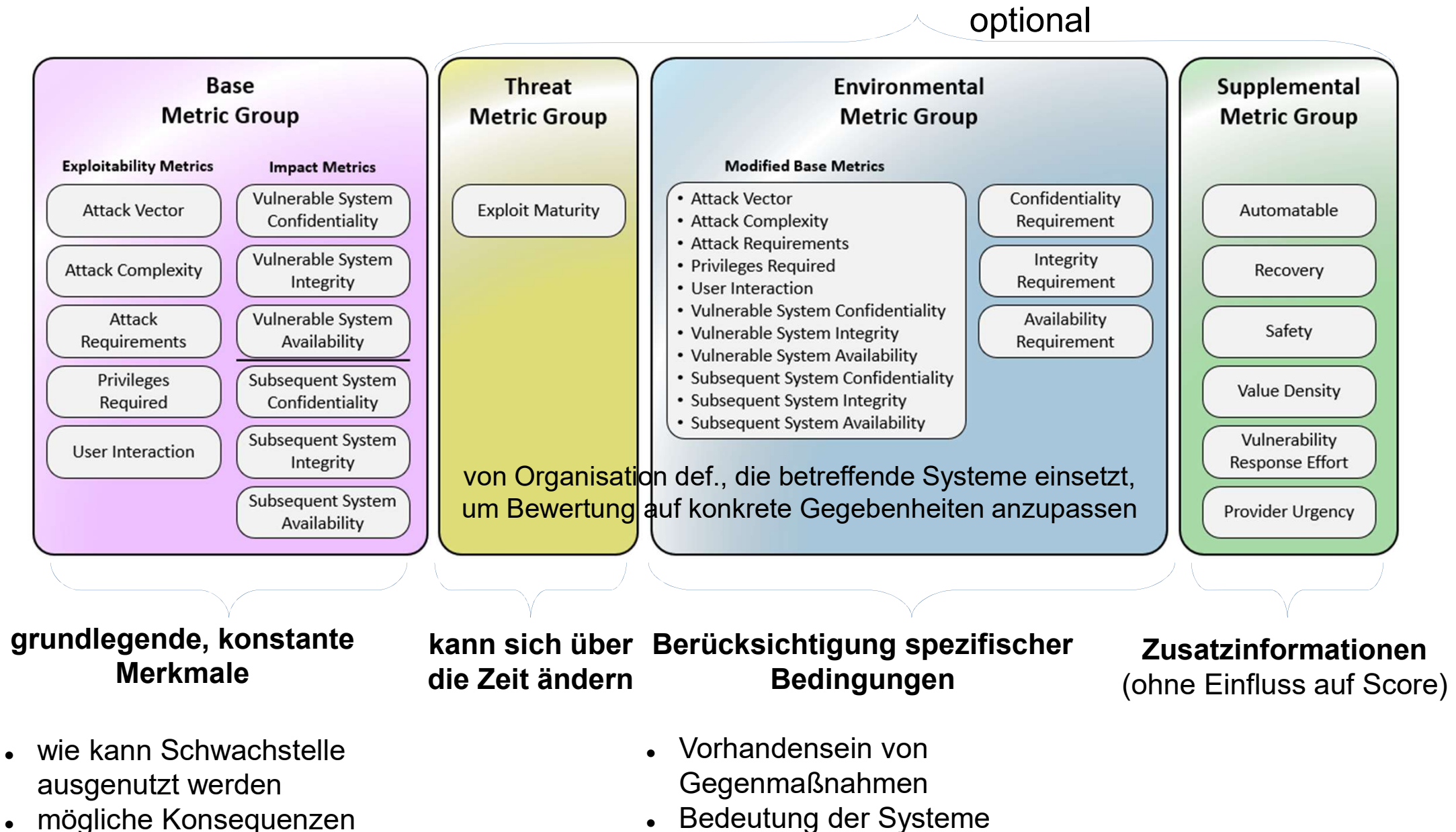
Known Affected Software Configurations [Switch to CPE 2.2](#)

Configuration 1 [\(hide\)](#)

cpe:2.3:a:code-projects:simple_chat_system:1.0:*:*:*:*:*

[Show Matching CPE\(s\)](#)

CVSS – Common Vulnerability Scoring System (Version 4.0)



Attack Vector (AV)

Network (AV:N) = remote ausnutzbar

Adjacent Network (AV:A) = LAN, Bluetooth, WLAN

Local (AV:L) = lokaler Systemzugriff, z.B. per Keyboard oder SSH

Physical (AV:P) = physischer Zugriff auf Hardware

Attack Complexity (AC)

Low (AC:L) = keine spez. Anforderungen

High (AC:H) = zusätzl. Aufwand für Umgehung von Sicherheitsmechanismen (z.B. ASLR umgehen, Passwort ermitteln)

Attack Requirements (AT)

Low (AT:L) = Angriffserfolg hängt nicht von Umgebungsbedingungen ab

High (AT:H) = bestimmte Voraussetzungen wie z.B. race condition nötig

Privileges Required (PR)

None (PR:N) = keine vorherige Authentifizierung erforderlich

Low (PR:L) = nur grundlegende Benutzerrechte

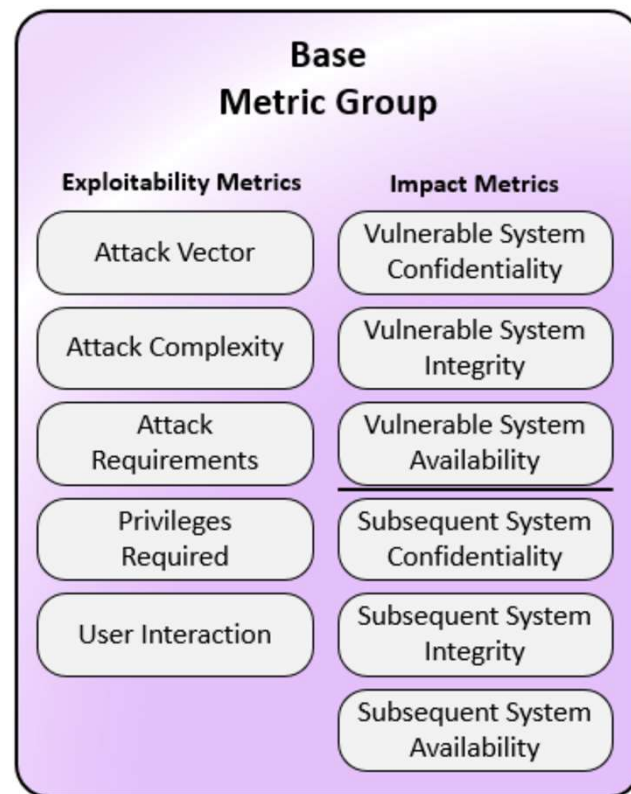
High (PR:H) = Adminrechte auf Einstellungen oder Dateien

User Interaction (UI)

None (UI:N) = keine Mitwirkung eines weiteren Nutzers erforderlich

Passive (UI:P) = unbewusste Mitwirkung erforderlich (z.B. Aufruf einer Webseite)

Active (UI:A) = bewusste Mitwirkung (z.B. Importieren einer Datei, Wegklicken von Sicherheitsmeldungen)



Impact auf CIA

- im verwundbaren System selbst (VC, VI, VA)
- in nachfolgenden Systemen (SC, SI, SA)

Abstufungen:

- None (N)
 - Low (L) = begrenzter oder vom Angreifer nicht beeinflussbarer Umfang
 - High (H)
- Master Informatik, TM40304

Exploit Maturity (E)

Not Defined (X) → für Score wie A behandelt (worst case)

Attacked (A) = Angriffe wurden beobachtet bzw. Exploit vorhanden

Proof-of-Concept (P) = lediglich PoC-Exploit veröffentlicht

Unreported (U) = keine Exploits vorhanden, keine Angriffe bekannt



Modified Base Metrics (MAV, MAC, MAT etc.)

- spiegelt bestehende Gegenmaßnahmen wider, z.B. betroffenes System wird in isoliertem Netzwerk betrieben (→ Score wird niedriger)
- Score kann sich aber auch erhöhen, wenn z.B. in Installation alle User Adminrechte haben

Confidentiality, Integrity, and Availability Requirements (CR, IR, AR)

berücksichtigt Auswirkungen auf Organisation, Kunden, Beschäftigte etc.

Not Defined (X) → für Score wie H behandelt (worst case)

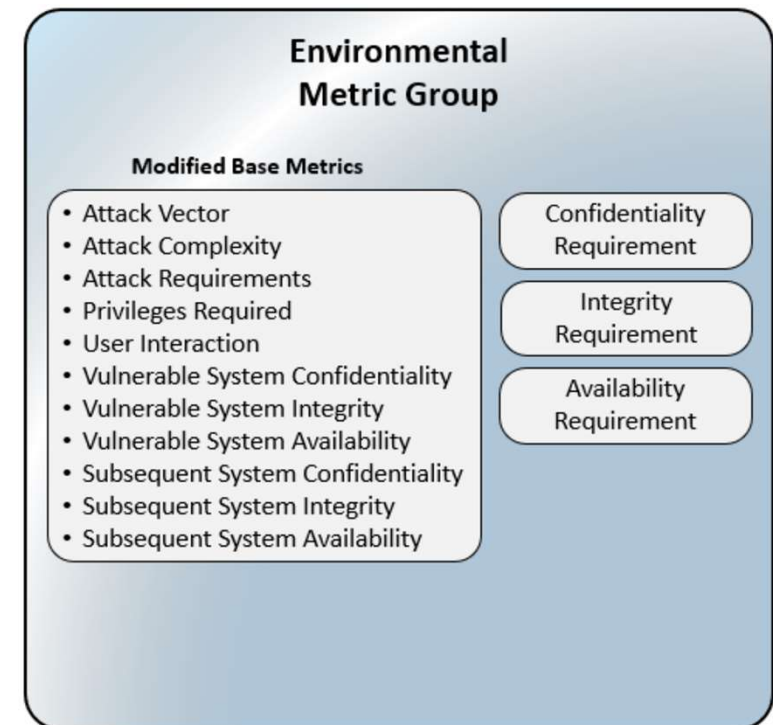
High (H) = katastrophal

Medium (M) = ernsthaft

Low (L) = nur begrenzt

falls Auswirkung auf **funktionale Sicherheit (Gefahr für Leib und Leben)**:

Modified Subsequent System Integrity (MSI) und **Modified Subsequent System Availability (MSA)** können mit Wert für Safety belegt werden (catastrophic, critical, marginal, negligible)



Automatable (AU)

Können Schritte 1-4 der „kill chain“ (reconnaissance, weaponization, delivery, exploitation) automatisiert werden?

No (N) Yes (Y)

Recovery (R)

Wie lässt sich ein betroffenes System wiederherstellen?

Automatic (A) User (U) Irrevocable (I)

Safety (S)

Sind Auswirkungen auf funktionale Sicherheit möglich? (vgl. vorige Folie)

Present (P) Negligible (N)

Value Density (V)

Wieviele Ressourcen kann Angreifer kontrollieren? (Bsp: einzelner Client vs. Server)

Diffuse (D) Concentrated (C)

Vulnerability Response Effort (RE)

Wie aufwändig ist die schnellstmögliche Reaktion auf die Schwachstelle? (z.B. Konfig.-änderung; einfaches Remote-Update oder Abschalten eines Teilsystems; Maßnahmen, die Downtime erfordern wie Hardware-Tausch oder umfangreich zu testende Software-Upgrades)

Low (L) Moderate (M) High (H)

Provider Urgency (PU)

Einschätzung des Hersteller in eigenem Security Advisory

Red Amber Green Clear

Supplemental Metric Group

Automatable

Recovery

Safety

Value Density

Vulnerability
Response Effort

Provider Urgency

falls jeweilige Metrik
nicht genutzt:

Not Defined (X)

Abb.: [https://www.first.org/cvss/v4-0/specification-document]
[https://nvd.nist.gov/vuln/detail/CVE-2025-3335]

Beispiel

Rating	CVSS Score
None	0.0
Low	0.1 - 3.9
Medium	4.0 - 6.9
High	7.0 - 8.9
Critical	9.0 - 10.0

CVSS Calculator:

<https://www.first.org/cvss/calculator/4-0>

CVE-2025-3335 Detail

Description

A vulnerability was found in codeprojects Online Restaurant Management System 1.0. It has been classified as critical. This affects an unknown part of the file /admin/category_update.php. The manipulation of the argument ID leads to sql injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 4.0 Severity and Vector Strings:

 **NIST: NVD**

N/A

NVD assessment not yet provided.

 **CNA: VulDB**

CVSS-B 6.9 MEDIUM

Vector:
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N

References to Advisories, Solutions

By selecting these links, you will be leaving NIST webspace. We have no way of knowing if they may have information that would be of interest to you. No information is being referenced, or not, from this page. There may be other web sites that are being referenced, or not, from this page. There may be other web sites that are being referenced, or not, from this page. NIST does not necessarily endorse the views expressed, or concur with the views expressed. NIST does not endorse any commercial products that may be mentioned on this page to nvd@nist.gov.

Hyperlink	
https://github.com/p1026/CVE/issues/49	Exploit
https://github.com/p1026/CVE/issues/49	Exploit
https://vuldb.com/?ctiid.303549	Permissions
https://vuldb.com/?id.303549	Third Party
https://vuldb.com/?submit.551909	Third Party

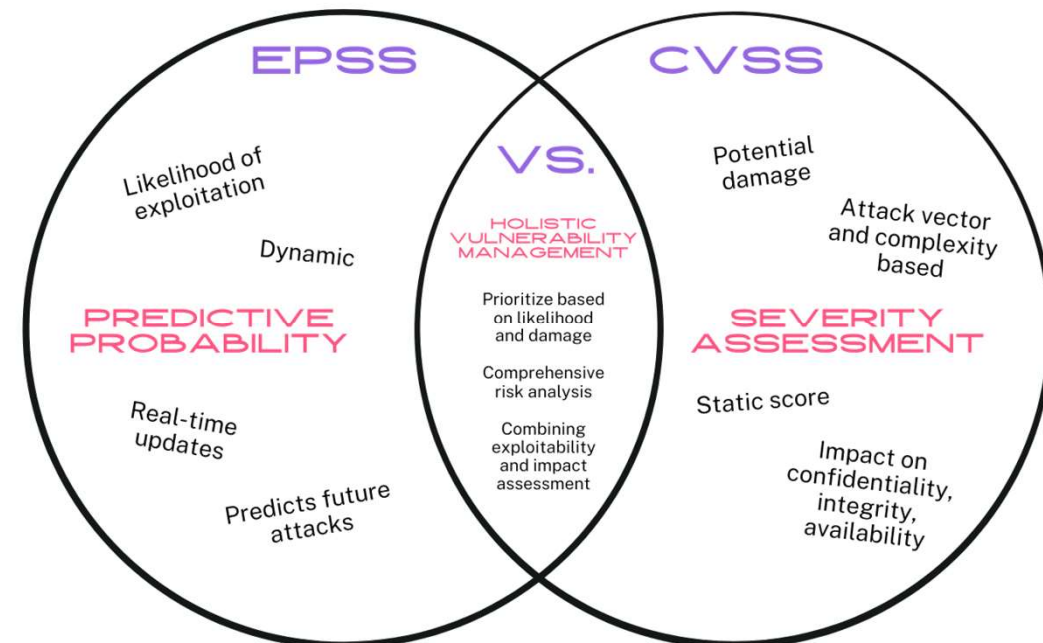
CVSS v4.0 Severity and Metrics:
CVSS-B: 6.9 MEDIUM
Vector:
AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N

Attack Vector (AV): Network
Attack Complexity (AC): Low
Attack Requirements (AT): None
Privileges Required (PR): None
User Interaction (UI): None
Vulnerable System Confidentiality (VC): Low
Vulnerable System Integrity (VI): Low
Vulnerable System Availability (VA): Low
Subsequent System Confidentiality (SC): None
Subsequent System Integrity (SI): None
Subsequent System Availability (SA): None

- Dynamischer, ML-basierter Ansatz zur Vorhersage der Wahrscheinlichkeit, dass eine bestimmte Schwachstelle ausgenutzt wird
 - Datenquellen: CVE-Datenbank, Telemetriedaten, historische Daten
 - berücksichtigt u.a. Verbreitung, Exploit-Verfügbarkeit, Schweregrad
- Ziel: Risikobewertung verbessern, Priorisierung erleichtern

- **täglich aktualisierter Datensatz:**
 - CVE-Nummer
 - Score = Wahrscheinlichkeit für Ausnutzung innerhalb 30 Tage
 - Perzentil (= Anteil aller Einträge mit gleichem oder geringerem Score)

[Abb.: <https://www.balbix.com/insights/what-is-epss-epss-vs-cvss/>]



Common Configuration Enumeration

<https://ncp.nist.gov/cce> (letztes Update: 7/2022)



- Beschreibungen von sicherheitsrelevanten Konfigurations-Einstellungen
- eindeutige IDs zur Vereinheitlichung über verschiedene Quellen und Tools hinweg

Attribut	Beispiel
Title	Disable Password Authentication for SSH
Discussion	...
Check	/usr/bin/grep -Ec '^(PasswordAuthentication\s+no ChallengeResponseAuthentication\s+no)' /etc/ssh/sshd_config
Fix	...
Quer- Verweise	– NIST SP 800-53 Rev. 5 (Security and Privacy Controls for Information Systems and Organizations) – DISA STIG (Defense Information Systems Agency Security Technical Implementation Guide), https://public.cyber.mil/stigs/ – CIS Security Configuration Benchmarks (Center for Internet Security, https://www.cisecurity.org/cis-benchmarks/)

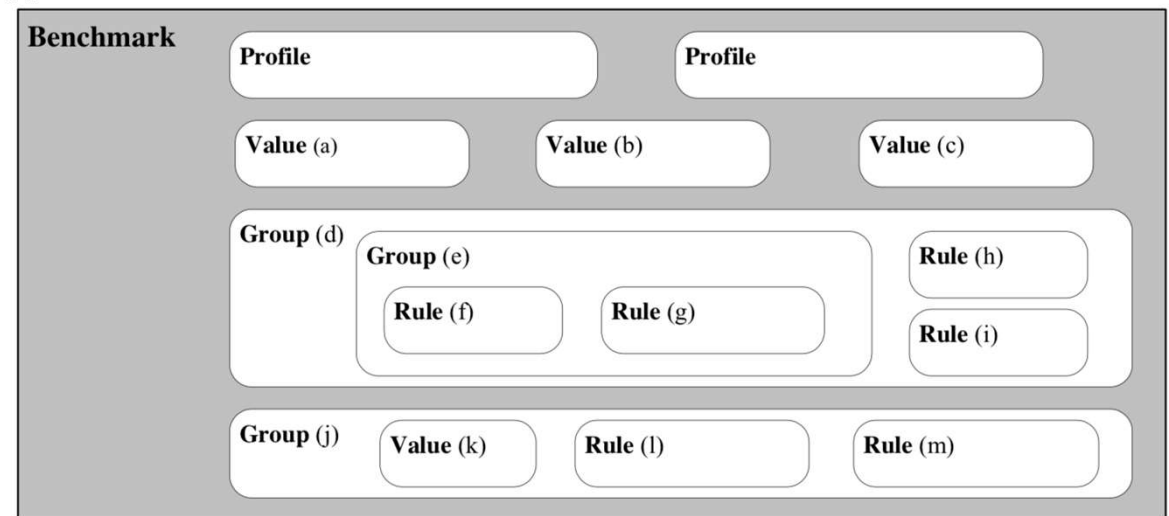
Extensible Configuration Checklist Description Format **XCCDF**



- standardisiertes Beschreibungsformat für Checklisten, eignet sich zur Überprüfung der Compliance

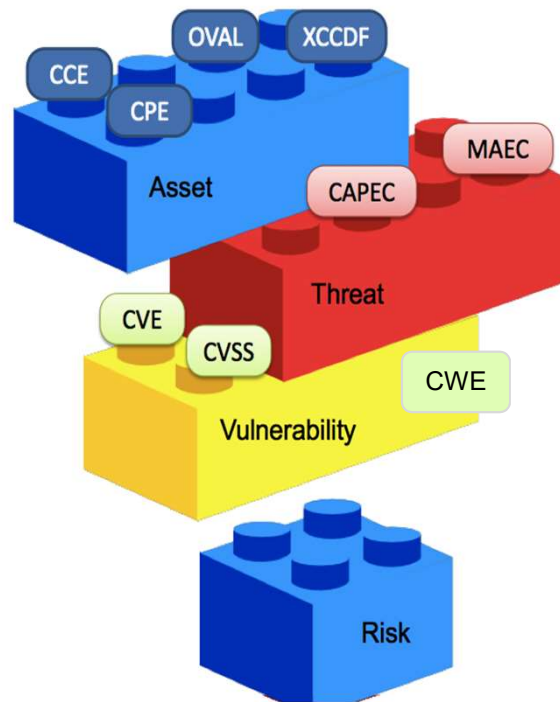
[\[https://csrc.nist.gov/projects/security-content-automation-protocol/scap-specifications/xccdf\]](https://csrc.nist.gov/projects/security-content-automation-protocol/scap-specifications/xccdf)

- Sammlung von Konfig.einstellungen für Klassen von Systemen



- **Rule:** einzelnes Prüfkriterium und ggf. konkrete Einstellung, z.B.
Password File Permission:
Check the access control on the password file.
Normal users should not be able to write to it.
Verweise auf CCE, CVE oder CERT-Advisories möglich
- **Value:** Definition, die an anderer Stelle verwendet wird, z.B. Vorgaben für Passwortlänge (minimale / tatsächliche Untergrenze)
- **Profile:** erlaubt Anpassungen der Anforderungen je nach Schutzbedarf, kann auf Rule-, Group-, Value-Elemente verweisen, Vererbung möglich

Zusammenhänge



CAPEC: Common **A**ttack **P**attern Enumeration and Classification

CCE: Common **C**onfiguration Enumeration

CPE: Common **P**latform Enumeration

CVE: Common **V**ulnerability and Exposures

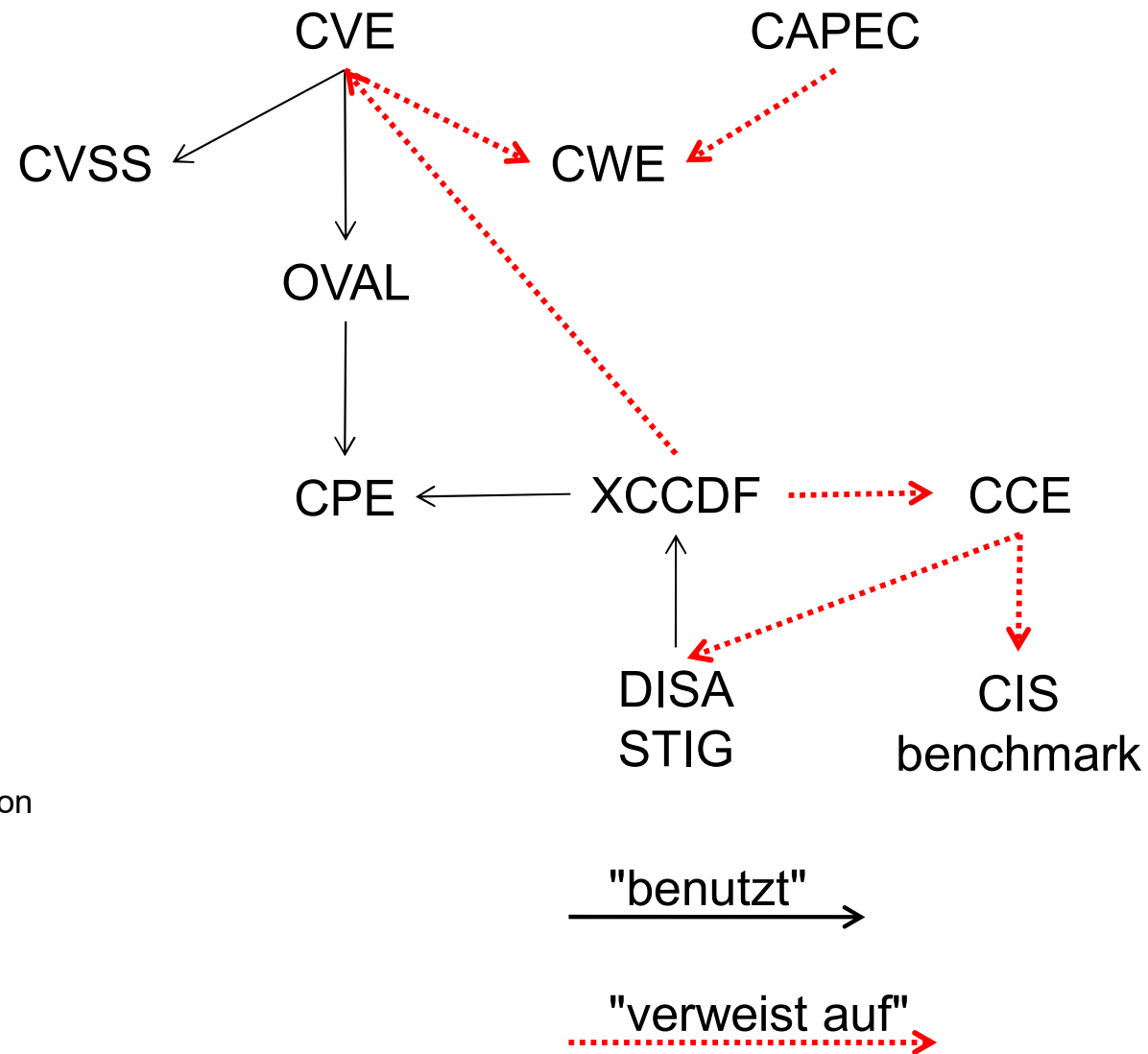
CVSS: Common Vulnerability **S**coring **S**ystem

CWE: Common **W**eakness Enumeration

MAEC: **M**alware Attribute Enumeration and Characterization

OVAL: Open Vulnerability and Assessment **L**anguage

XCCDF: eXtensible **C**onfiguration **C**hecklist Description Format



Praxis-Bsp: Security Database Dashboard

häufigste Schwachstellen:

- (B) CWE-79 Cross-Site-Scripting
- (C) CWE-119 Improper Restriction of Operations within the Bounds of a Memory Buffer
- (B) CWE-89: SQL Injection
- (B) CWE-787: Out-of-bounds Write
- (C) CWE-20: Improper Input Validation

<https://www.security-database.com/dashboard.php>

(Stand: 5/2024, nicht mehr verfügbar)

Overall CWE

CWE	%	Affected CVE
CWE-79	15%	26 531
CWE-119	6%	11 495
CWE-89	6%	11 297
CWE-787	5%	9 969
CWE-20	5%	9 289



sehr ähnliches Ranking bei Mitre:

<https://cwe.mitre.org/top25/index.html>

Praxis-Bsp: Exploits



- <https://exploit-db.com/>
- CVE-konformes Archiv von Exploits und verwundbarer Software

Laravel Framework 11 - Credential Leakage

- Kategorien:
 - DoS
 - local
 - remote
 - webapps

EDB-ID: 52000	CVE: 2024-29291	Author: HUSEEIN AMER	Type: WEBAPPS	Platform: PHP	Date: 2024-04-21
EDB Verified: ✗		Exploit: ⬇ / {}		Vulnerable App:	



```
# Exploit Title: Laravel Framework 11 - Credential Leakage
# Google Dork: N/A
# Date: [2024-04-19]
# Exploit Author: Huseein Amer
# Vendor Homepage: [https://laravel.com/]
# Software Link: N/A
# Version: 8.* - 11.* (REQUIRED)
# Tested on: [N/A]
# CVE : CVE-2024-29291

Proof of concept:
Go to any Laravel-based website and navigate to storage/logs/laravel.log.

Open the file and search for "PDO->__construct('mysql:host='".
The result:
shell
Copy code
#0
/home/u429384055/domains/js-cvdocs.online/public_html/vendor/laravel/framework/src/Illuminate/Database/Connectors/Connector
PDO->__construct('mysql:host=sql1...', 'u429384055_jscv', 'Jaly$a0p0p0p0',
Array)
```